

SECURITY & COMPLIANCE ARCHITECTURE REPORT

TrustInterview AI

Zero Trust Architecture, Bias Mitigation, & Factuality Filters

2.0 (Version Trust Enforced)

PUBLISHED: Q3, 2026

AUTHOR: Antigrain Engineering Division

1. Executive Summary & Intro

TrustInterview AI is an enterprise-grade, privacy-first talent assessment platform designed to evaluate candidate qualifications fairly and securely. Conventional online interview tools suffer from severe vulnerabilities, including automated bot screening bypasses, prompt injection attacks, resume fraud, and human evaluation bias.

To mitigate these vulnerabilities, the system implements a Zero Trust Architecture (ZTA) spanning 13 security and validation layers. The core directive of this architecture is 'Never Trust, Always Verify' — applying continuous authentication, live device forensics, data sanitisation, AI bias filtering, and factuality grounding to every API request and response.

The Core Pillars of the Platform:

- **Continuous Verification:** Every action is cryptographically signed, bound to a specific session token, and continuously checked for posture changes.
 - **Compliance & Fairness:** Decouples PII (Personally Identifiable Information) from evaluations and audits both questions and scores to prevent systemic demographic bias.
 - **AI Fact Grounding:** Monitors LLM input and output for integrity, ensuring questions match verified resume content and identifying candidate factual discrepancies (hallucination).
-

2. Zero Trust Architecture (ZTA) Layer Matrix

The system's backend enforces a strict sequence of 13 security layers. If any check fails, the session is terminated and marked as blocked.

- **L1: Identity & Session Signatures:** Enforces cryptographic session signatures. Every non-public API call must provide a valid session token generated by the server.
- **L2: Device Fingerprinting:** Analyzes client header telemetry to build a unique hardware/software signature, immediately blocking headless browsers (Selenium, Puppeteer, Playwright).
- **L3: Network & CORS Segregation:** Locks cross-origin access strictly to designated application domains (e.g. localhost:3000), rejecting remote script injection.

2. The 13 ZTA Layers (Continued)

- **L4: Workload Security:** Imposes strict payloads caps (10MB for JSON and PDFs) to prevent denial-of-service memory exhaustion.
- **L5: Data Protection:** Ensures zero-retention storage. Uploaded PDF resumes are extracted, parsed in memory, and permanently deleted from disk within 100 milliseconds.
- **L6: Structured Audit Logging:** Logs all API actions into SIEM-compatible JSON lines. Captures IP, headers, device fingerprints, and response times without logging candidate PII.
- **L7: SOAR Automation:** Security Orchestration, Automation, and Response. Automatically maps, logs, and blocks IPs that exceed suspicious request rates or trigger too many errors.
- **L8: Governance & GDPR Sanitisers:** Deep-scans POST request payloads to sanitize SQL injection fragments, XSS tags, and protect against accidental credential leakage (e.g. OpenAI keys).
- **L9: Policy Decision Point (PDP):** Acts as the central access gatekeeper, matching every incoming request against a defined policy schema (method validation, max session age).
- **L10: Edge Security & Cryptography:** Forces secure transport headers (HSTS), frame-injection blocks, and securely-scoped cookies to secure browser endpoints.
- **L11: Threat Intelligence blocklist:** Maintains an active signature table blocking known malicious IP subnets and exploit script signatures.
- **L12: Human Factors & Bias Shield:** Filters evaluation outputs through a demographic and personal name protection scanner before it is logged or presented to recruiters.
- **L13: Fact Grounding & Hallucination Audit:** Cross-references candidate answers and AI question sets against the source resume to ensure grounding truthfulness.

3. L12: AI Bias & Fairness Shield

One of the primary goals of TrustInterview AI is to eliminate human and machine-generated demographic bias. During evaluation, OpenAI or Gemini models score candidates, but these models can sometimes generate feedback containing implicit biases (e.g. accent criticism, references to age, or gender assumptions).

The Bias Shield (Layer 12) runs a strict post-evaluation check. It scans the feedback text for 12 categories of prohibited terms: Age, Gender, Race/Ethnicity, Religion, Nationality, Disability, Accent, Background, Family, Married, Children, and Pregnancy Status.

3. L12: AI Bias & Fairness Shield (Continued)

Additionally, the system extracts the candidate's first and last names (e.g. 'triveni reddy') and dynamically registers them as an extra bias filter category. The evaluator is forbidden from addressing the candidate by name or referring to personal traits, forcing evaluations to focus strictly on technical merit and communication quality.

If any category is triggered, the compliance audit score drops, a warning is logged in the audit database, and the flagged evaluation is withheld or scrubbed. A 100% compliant score indicates complete neutrality.

4. L13: Anti-Hallucination & Fact Grounding

Candidates often exaggerate credentials, while generative AI models can invent questions or expectations not justified by the candidate's actual background. Layer 13 addresses this by enforcing dual-directional grounding checks:

A. AI Question Grounding Audit

When questions are generated, the system cross-references each question against the extracted text of the candidate's resume. It searches for occurrences of the skills, technologies, and companies mentioned in the question. If a question references a technology not present in the resume (e.g. asking about 'Kubernetes' when the resume only lists 'Docker'), it flags a grounding violation and rolls back to standard validation questions.

B. Candidate Answer Hallucination Checker

When a candidate provides an answer, the system audits the claims made. It extracts technical assertions, years of experience, and project references, and runs semantic mapping against the resume database. If the candidate claims experience with a framework or level of responsibility not supported by their CV, a hallucination risk score (0-100%) is calculated. If the risk exceeds 50% (Mostly Grounded), the system flags the claim as 'Unverified' on the final recruiter dashboard.

5. Threat Detection & SOAR Auto-Blocking

TrustInterview AI is designed to defend itself autonomously. The SOAR (Layer 7) middleware monitors all requests in a rolling 10-minute window. If a client starts scanning the endpoints (triggering too many 404 or 401 errors) or sends malicious scripts (triggering 400 Governance blocks), the threat counter increments.

How ZTA is Made Inactive / Blocked:

- **Threshold Breaches:** If an IP triggers more than 40 bad requests (4xx) or 20 server errors (5xx) within 10 minutes, the SOAR engine automatically blocks the IP.
 - **Session Termination:** The block list entry sets a 'blockedUntil' timestamp 30 minutes in the future, throwing a 429 rate limit exception for all subsequent connections.
 - **Live Status Update:** When the status endpoint (/api/zta-status) is queried, it evaluates the requesting IP. If flagged, it sets 'fraudAlert: true' and 'ztaEnabled: false'.
 - **UI Dashboard Lock:** The frontend status dashboard immediately turns crimson, displays 'ZTA BLOCKED — FRAUD/TAMPERING DETECTED', and locks all layers as BLOCKED. The 'Start Interview' button becomes completely disabled, isolating the threat.
-

6. Summary of Engineering Enhancements

During the security and stability audit, the following vulnerabilities were identified and resolved:

- **CORS & Port Alignment:** Aligned the backend CORS origin policy to allow requests from http://localhost:3000 (React client), preventing preflight request drops.
- **Status Endpoint Policies:** Registered /api/zta-status in public routes and the PDP schema, enabling the frontend dashboard to display live ZTA integrity states securely on mount.
- **Governance Content-Type Bypass:** Bypassed content-type checks on empty POST requests (like /api/auth/session) so bootstrap handshakes complete successfully.
- **API Failover (Gemini 1.5):** Created a transparent failover system using Google Gemini 1.5 Flash when OpenAI quota thresholds are reached, ensuring uninterrupted operations.
- **Live Mic Web Speech Integration:** Implemented Web Speech API integration in the frontend, enabling local speech recognition directly in the browser.

